GALALA UNIVERSITY
Powered by
Arizona State University®

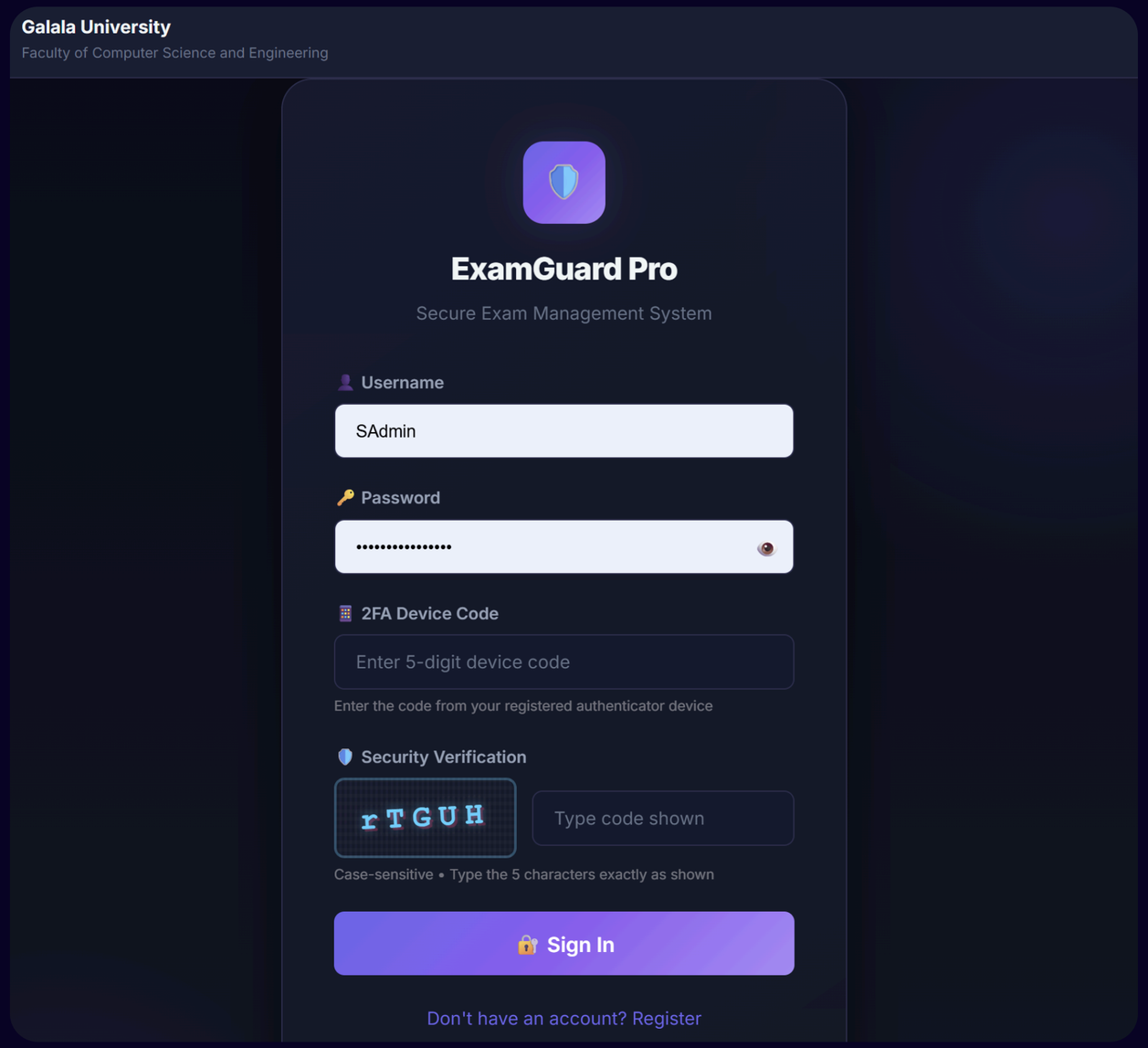
EXAM MANAGEMENT SYSTEM



CSE243 Secure Programming Course Project
Supervised By: Dr. Mohamed Mead
Spring 2025/26

Team:
Omar Khalifa 223101614 CE
Samaa Mohamed 223101629 CE

GALALA UNIVERSITY
Powered by
Arizona State University®



OVERVIEW

ExamGuard is a full-stack web-based Exam Management System designed to digitize the complete examination lifecycle from question authoring to grading and analytics. It enforces strict role separation and applies a security-first design at every layer.

GOALS

- Online Exam Management System with security-first SSDLC approach.
- 10 security domains aligned with OWASP Top 10.
- Technology: Node.js + Express.js + SQLite3 + crypto module.
- Defense-in-depth: 5 security layers from network to data.
- Modular code: each security concern in its own middleware file.

GALALA UNIVERSITY
Powered by
Arizona State University®

SYSTEM INTERFACES AND ROLES

Student

Students who take exams in strict modes. Chat with teachers, Enter Groups or take roles for Projetcs, Join Exam rooms and review their grades

Super Admin

a Super Admin who manages the platform. They can Edit users and roles and accessability. Read Logs and Monitor The platform

Teacher

a Teacher who creates and grades exams, Can assign groups or students roles, chat with students.



GALALA UNIVERSITY
Powered by
Arizona State University®

SECURE REQUIREMENTS ABUSE CASES

ID	Abuse Case — Attacker Goal	Countermeasure (Implemented)
AC-01	Attacker performs SQL injection on the login form to bypass authentication and gain unauthorized access	Parameterized queries on ALL database operations: db.prepare("SELECT * FROM users WHERE username = ?").get(username) — user input is never concatenated into SQL strings.
AC-02	Attacker performs brute-force password guessing to compromise any account	express-rate-limit: 5 login attempts per minute per IP; account locked after 5 failures; CAPTCHA on login page; lockout_until timestamp stored in users table.
AC-03	Attacker injects XSS payload in registration fields to steal session tokens or redirect users	validator.escape() on all input fields (except password); Content-Security-Policy header restricts script sources to 'self'; HttpOnly cookies prevent JS token access.
AC-04	Attacker steals session cookie via XSS or network interception to impersonate a user	Cookie flags: HttpOnly (no JS access) + Secure (HTTPS only) + SameSite=Strict (no cross-site sending) + maxAge=7200000 (2hr expiry).
AC-05	Attacker uses CSRF to trick an authenticated user's browser into submitting a malicious exam	Per-request CSRF tokens stored in csrf_tokens table; single-use (deleted after validation); token required in body (_csrf) or header (x-csrf-token) for all POST/PUT/DELETE.
AC-06	Student navigates away from exam tab to search for answers (tab switching / focus loss)	WebSocket anti-cheat: tab switch and focus_loss events recorded to proctoring_events table; is_flagged set on exam_session; negative marking applied to final grade; auto-submit triggered.
AC-07	Student manipulates URL or JWT to access instructor or admin routes	RBAC authorize() middleware checks req.user.role against allowedRoles on every protected route; unauthorized attempt logged to audit_logs with UNAUTHORIZED_ACCESS_ATTEMPT action.

GALALA UNIVERSITY
Powered by
Arizona State University®

RISK ANALYSIS MATRIX

Risk	Impact	Likelihood	Mitigation
SQL Injection	Critical	High	Parameterized queries (?.?)
XSS (Reflected/Stored)	High	Medium	validator.escape() + CSP headers
Brute Force	High	High	Rate limit + lockout + CAPTCHA
Session Hijacking	Critical	Medium	HttpOnly/Secure/SameSite cookies
CSRF	High	Medium	Per-request CSRF tokens
Privilege Escalation	Critical	Low	RBAC + ABAC middleware
Data Breach	Critical	Low	AES-256 + PBKDF2 encryption

GALALA UNIVERSITY
Powered by
Arizona State University®

THREAT DIAGRAMS

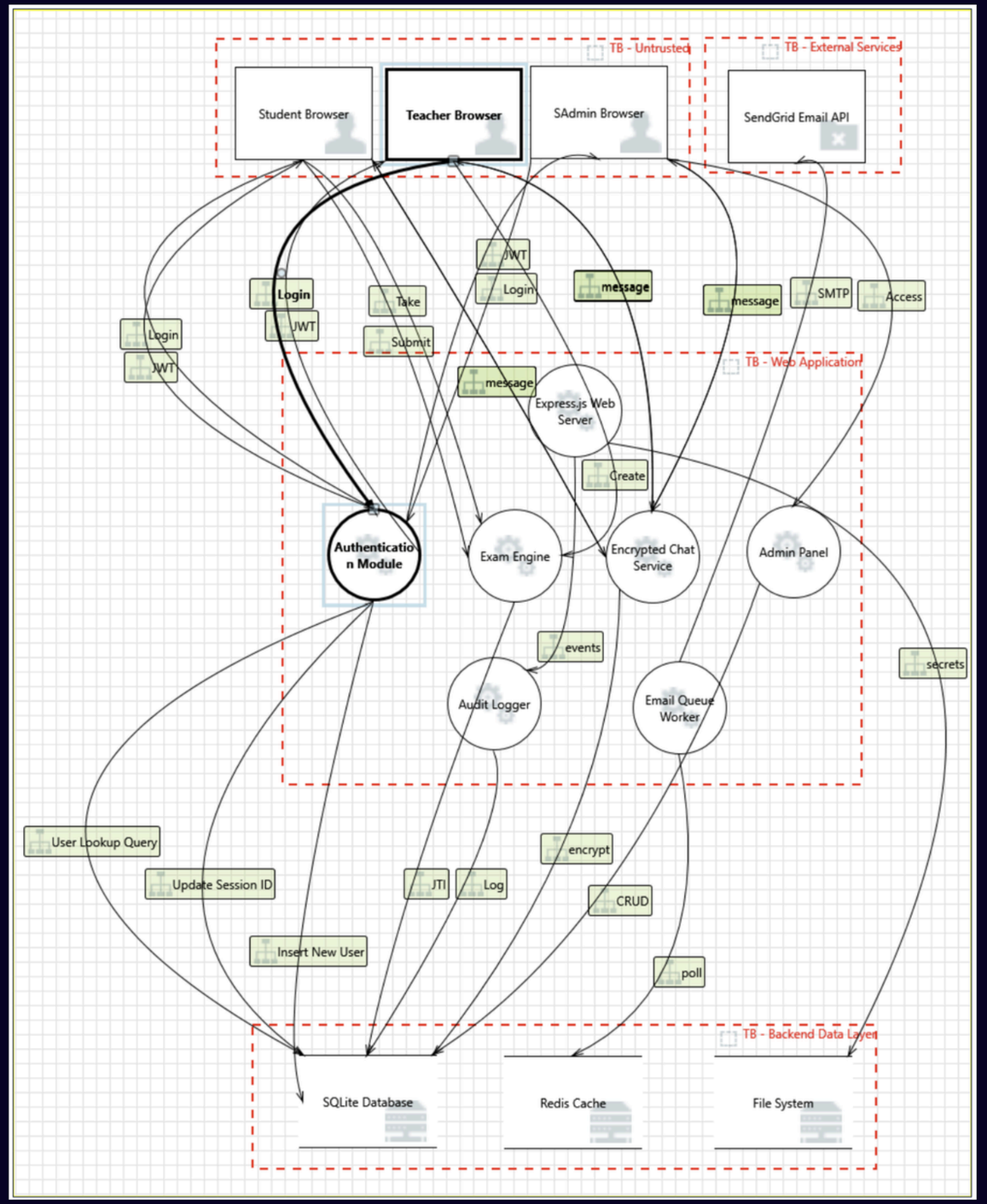
GALALA UNIVERSITY
Powered by Arizona State University®

STRIDE THREAT MODEL

Threat	Description	Mitigation
Spoofing	Fake identity / impersonation	JWT auth, CAPTCHA, 2FA, session binding
Tampering	Modify data in transit/storage	CSRF tokens, input validation, parameterized SQL
Repudiation	Deny performing an action	Immutable append-only audit log, IP tracking
Info Disclosure	Expose sensitive data	AES-256-CBC, PBKDF2, RSA, generic errors
Denial of Service	Overwhelm system resources	Rate limiting (100 req/min), account lockout
Elevation of Privilege	Gain unauthorized access	RBAC hierarchy + ABAC (dept+time+clearance)

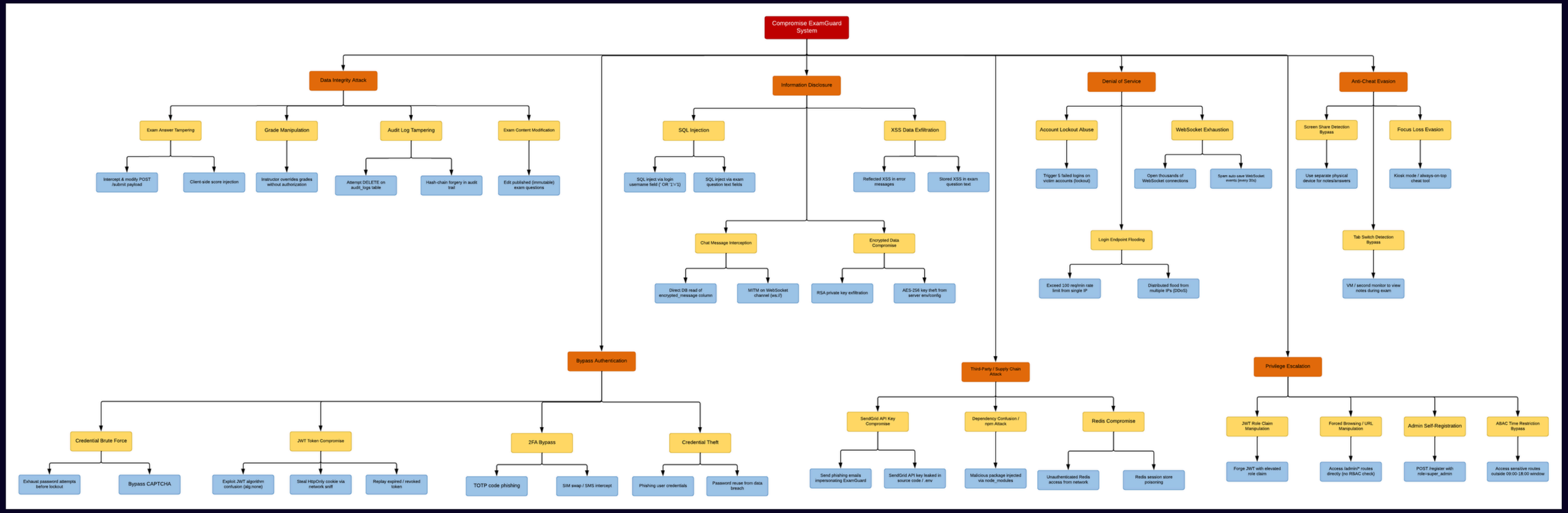
GALALA UNIVERSITY
Powered by
Arizona State University®

STRIDE THREAT MODEL



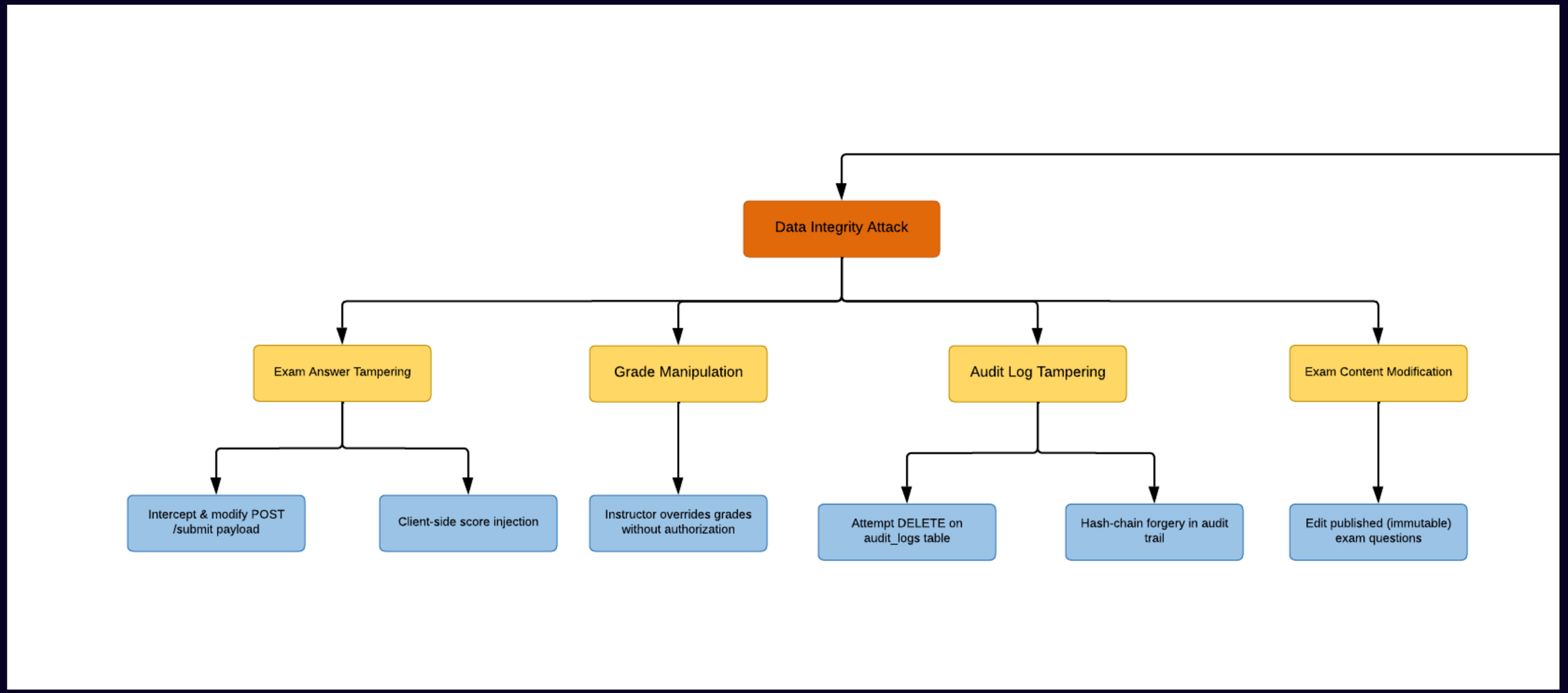
GALALA UNIVERSITY
Powered by
Arizona State University®

THREAT TREE DIAGRAM ATTACK SURFACE



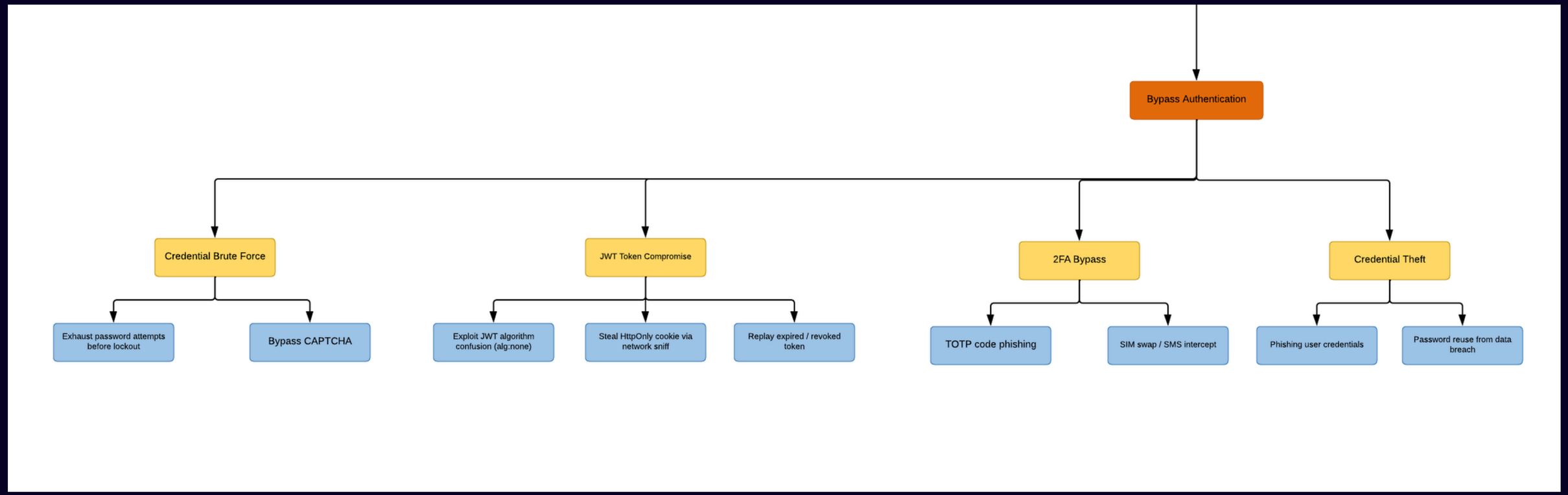
GALALA UNIVERSITY
Powered by
Arizona State University®

THREAT TREE DIAGRAM ATTACK SURFACE



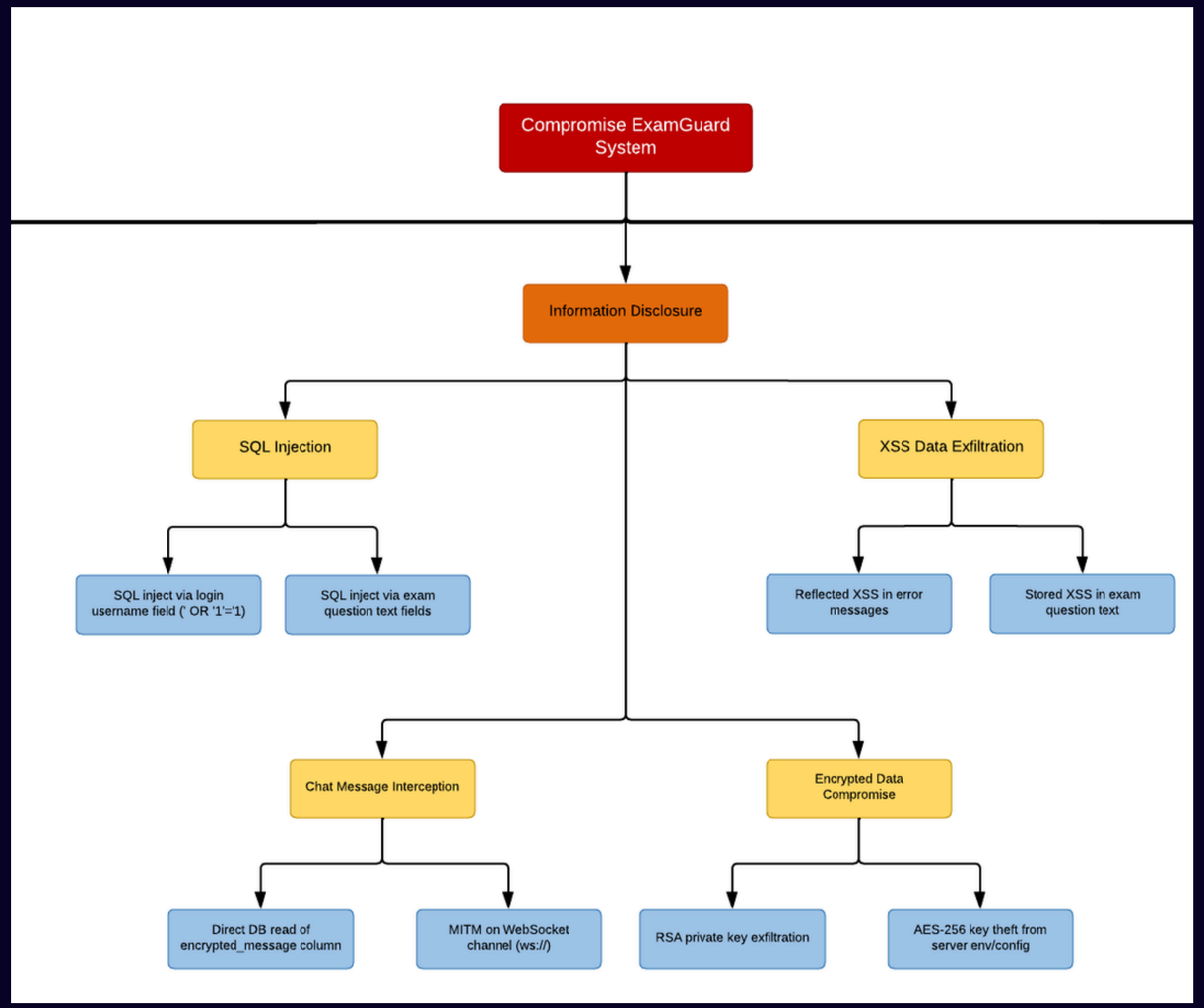
GALALA UNIVERSITY
Powered by
Arizona State University®

THREAT TREE DIAGRAM ATTACK SURFACE



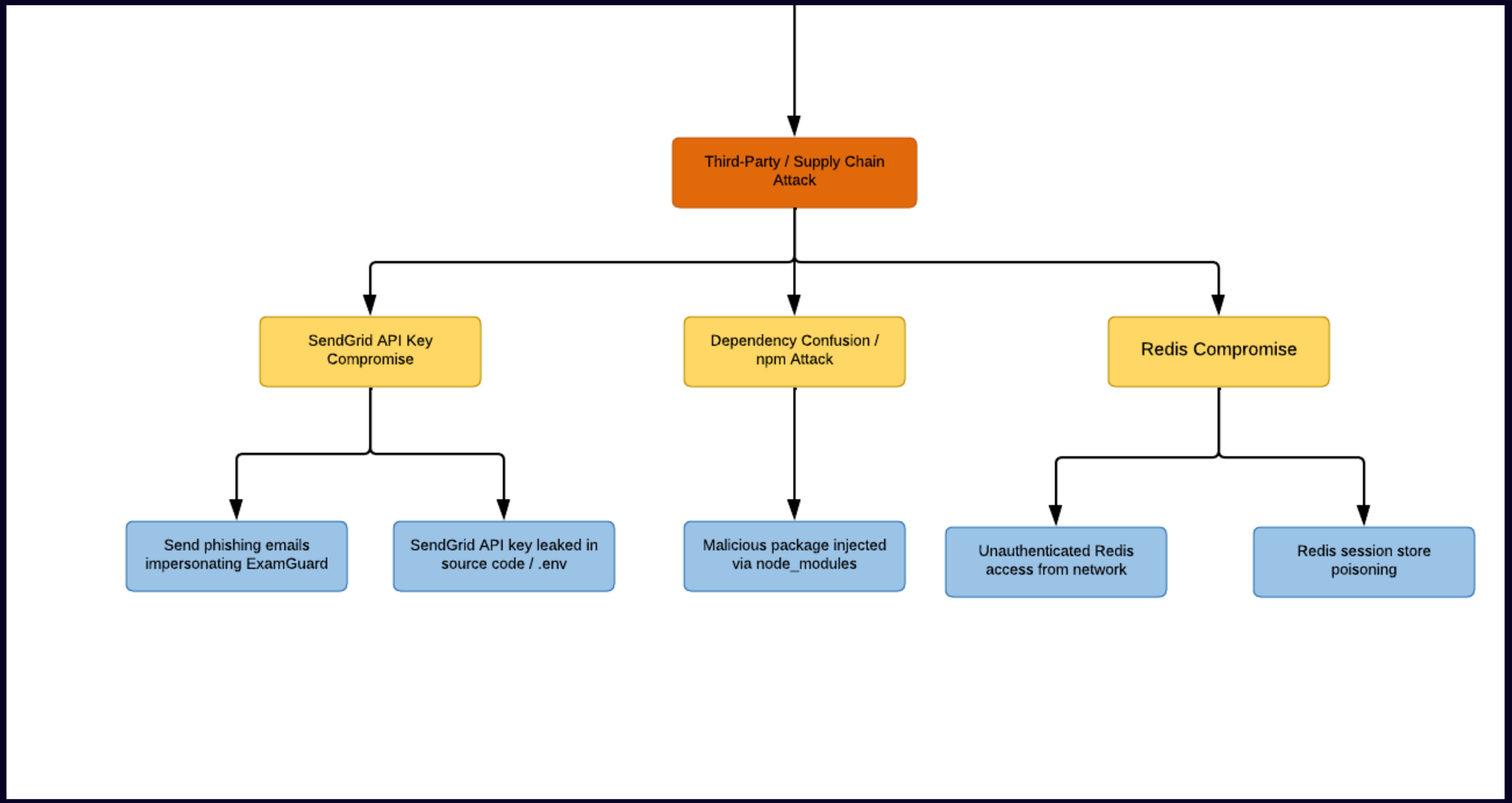
GALALA UNIVERSITY
Powered by
Arizona State University®

THREAT TREE DIAGRAM ATTACK SURFACE



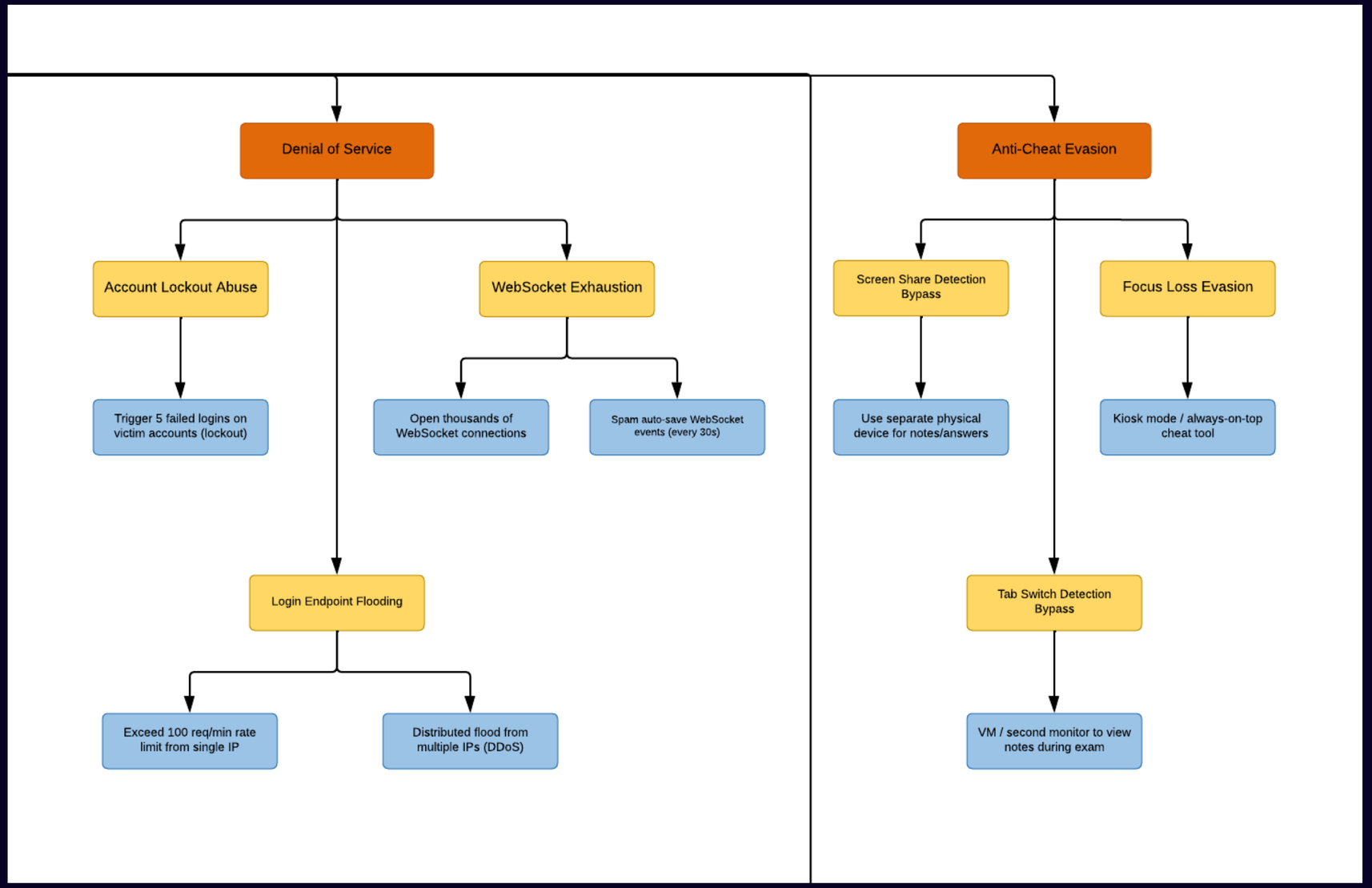
GALALA UNIVERSITY
Powered by
Arizona State University®

THREAT TREE DIAGRAM ATTACK SURFACE



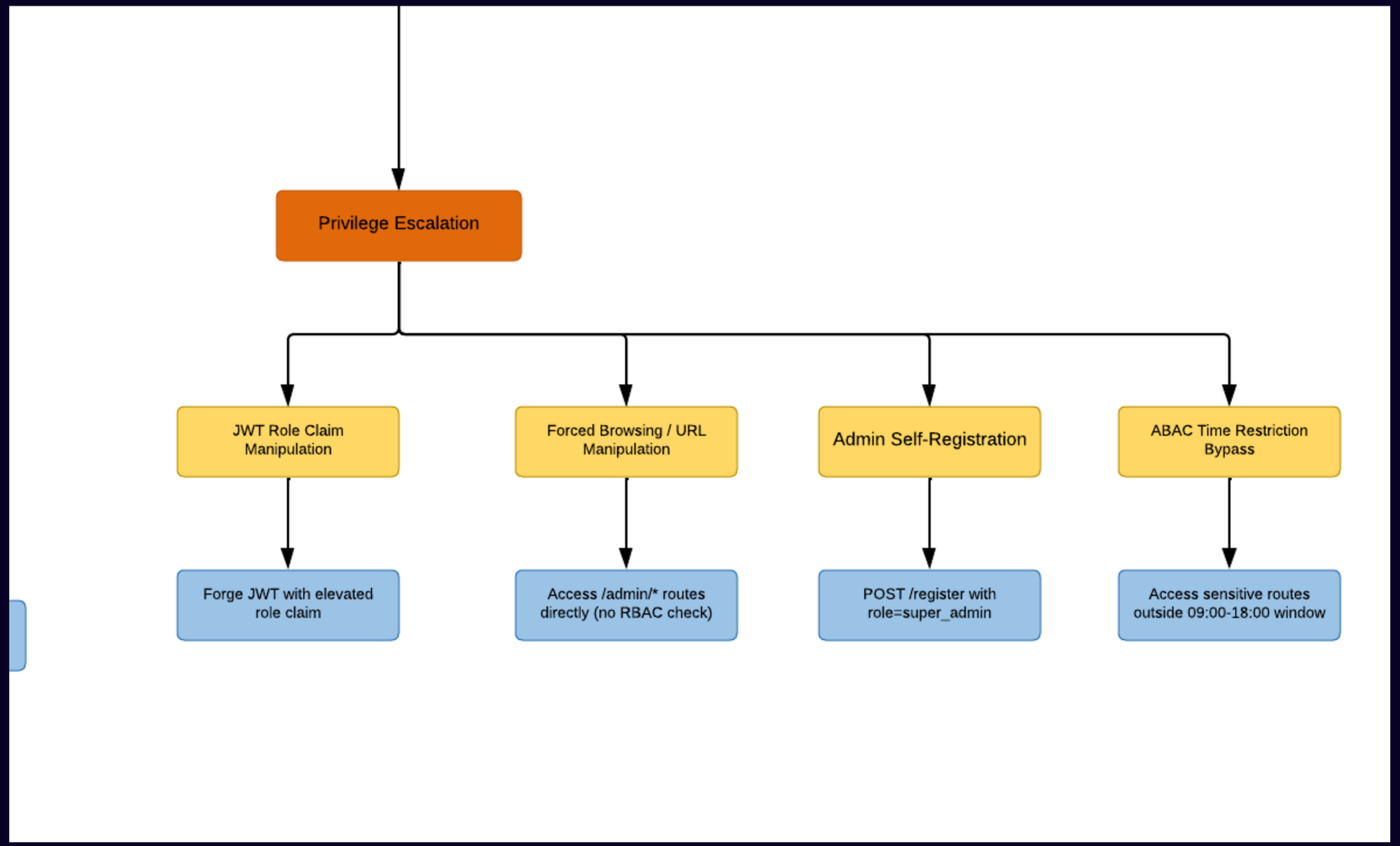
GALALA UNIVERSITY
Powered by
Arizona State University®

THREAT TREE DIAGRAM ATTACK SURFACE



GALALA UNIVERSITY
Powered by
Arizona State University®

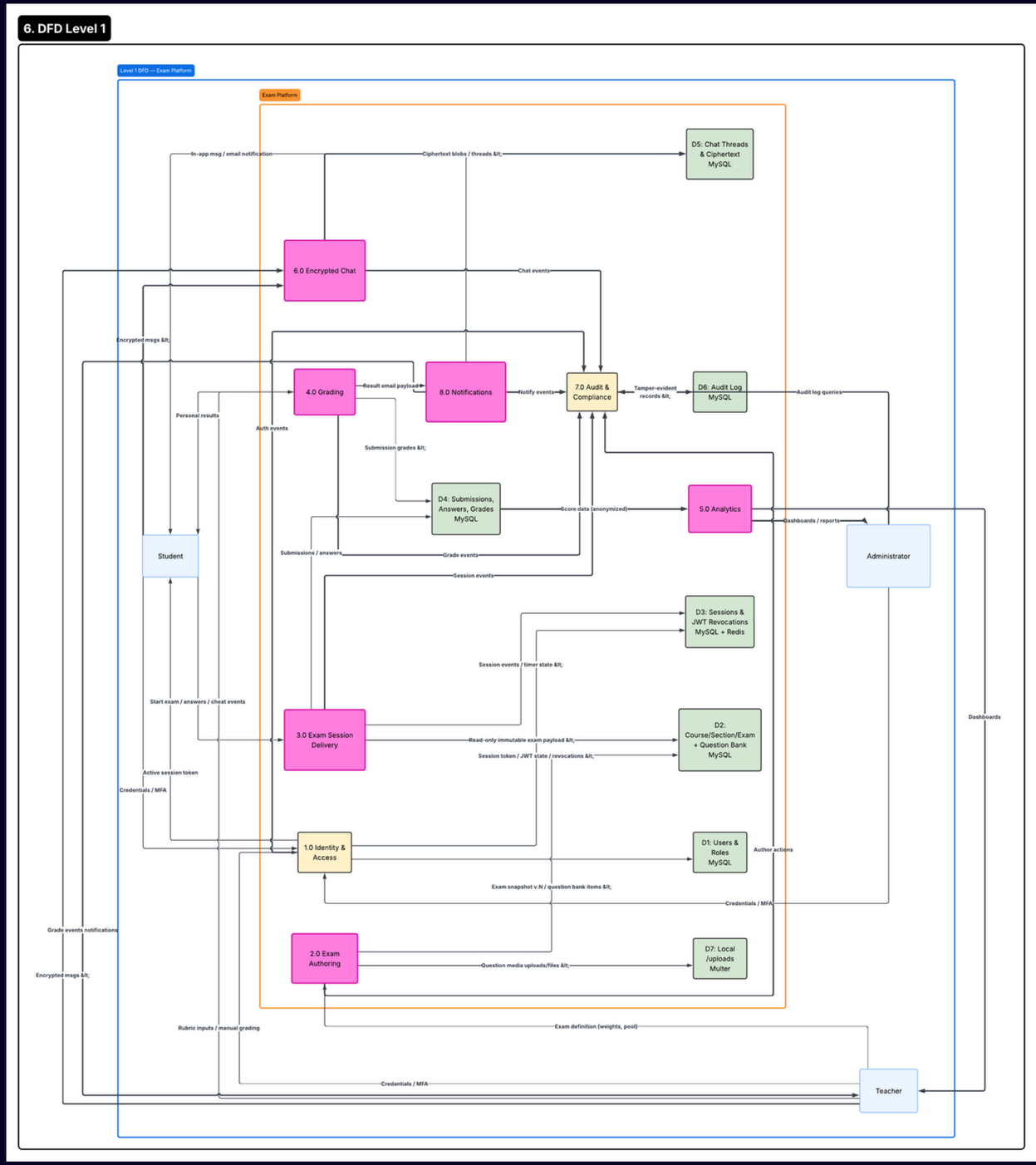
THREAT TREE DIAGRAM ATTACK SURFACE



GALALA UNIVERSITY
Powered by
Arizona State University®

DFD

Shows how data moves through the system — from input to processing to storage. It breaks the system into internal processes and shows which data stores are read/written by each process.

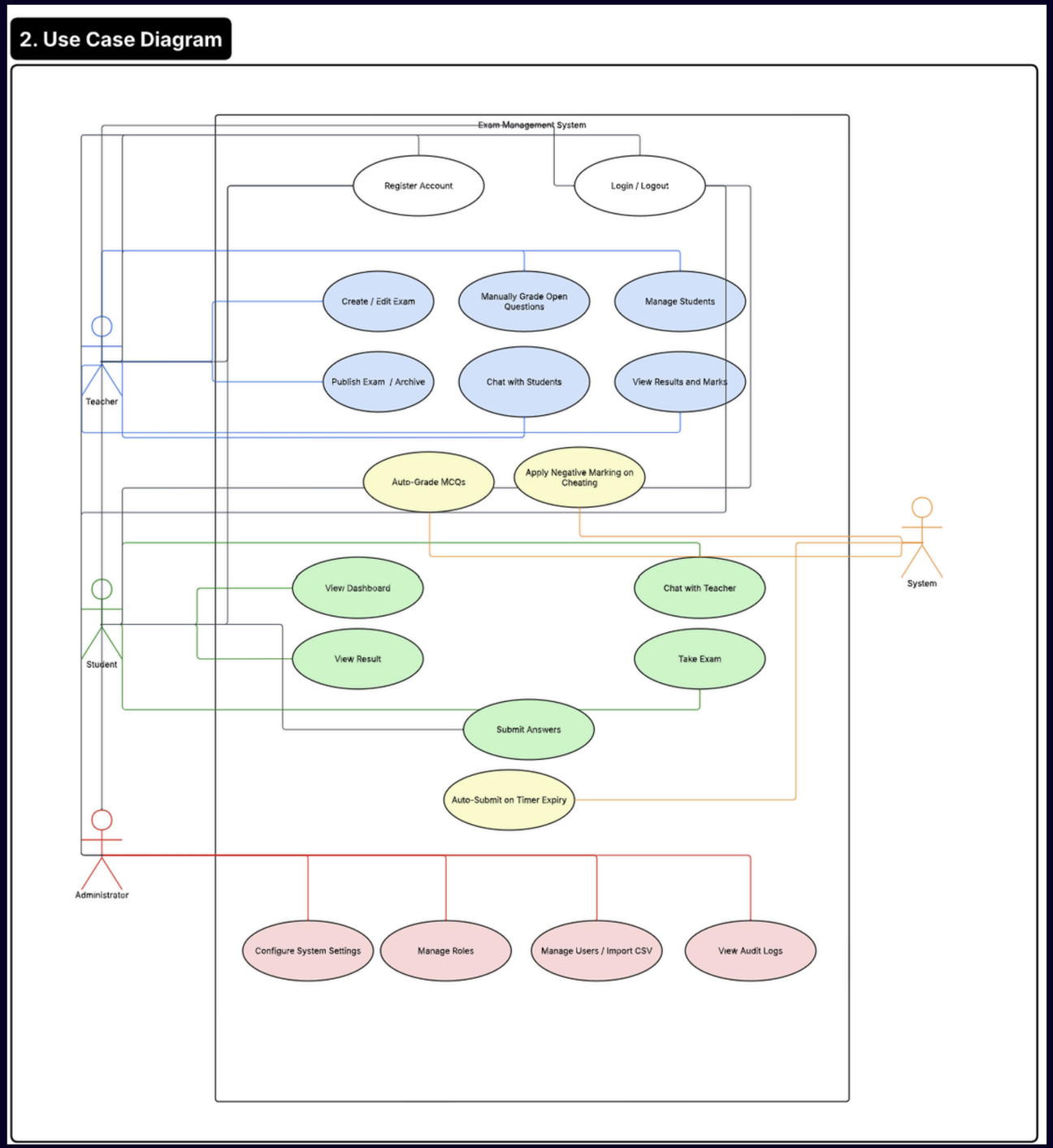


GALALA UNIVERSITY
Powered by
Arizona State University®

USE CASE DIAGRAM

Shows what the system can do and who does what. It lists all the features/functions (use cases) and maps them to the actors (users/roles) who trigger them, no technical detail, just capabilities.

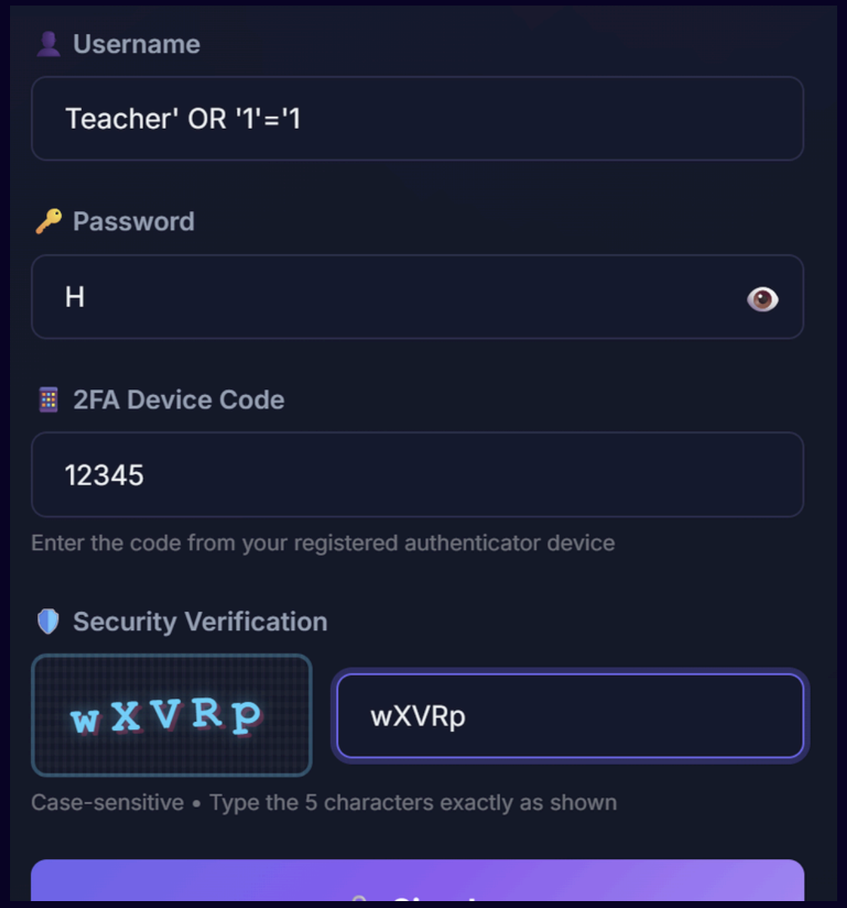
2. Use Case Diagram

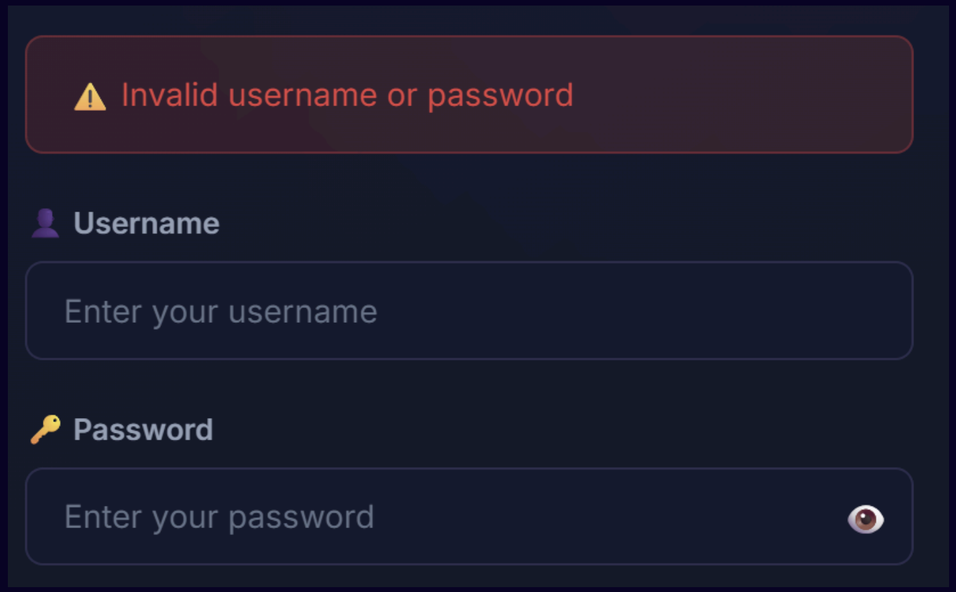


GALALA UNIVERSITY
Powered by
Arizona State University®

DEMO TIME

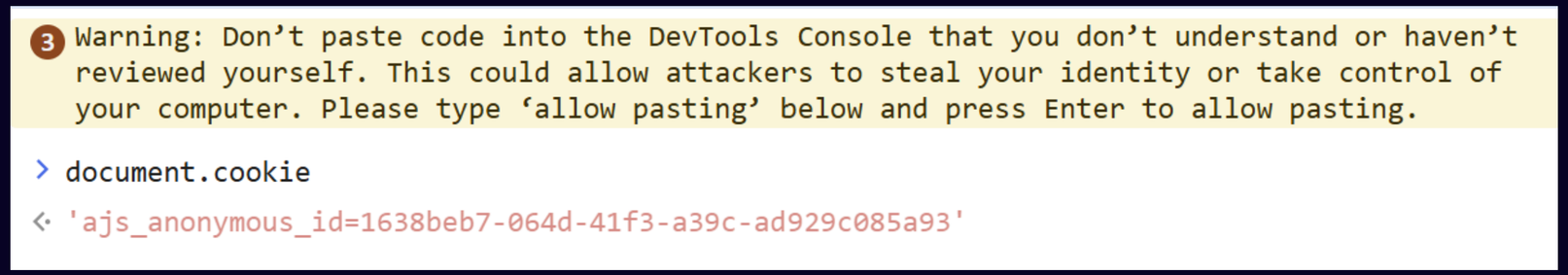
SQL INJECTION (SQLI) PROTECTION





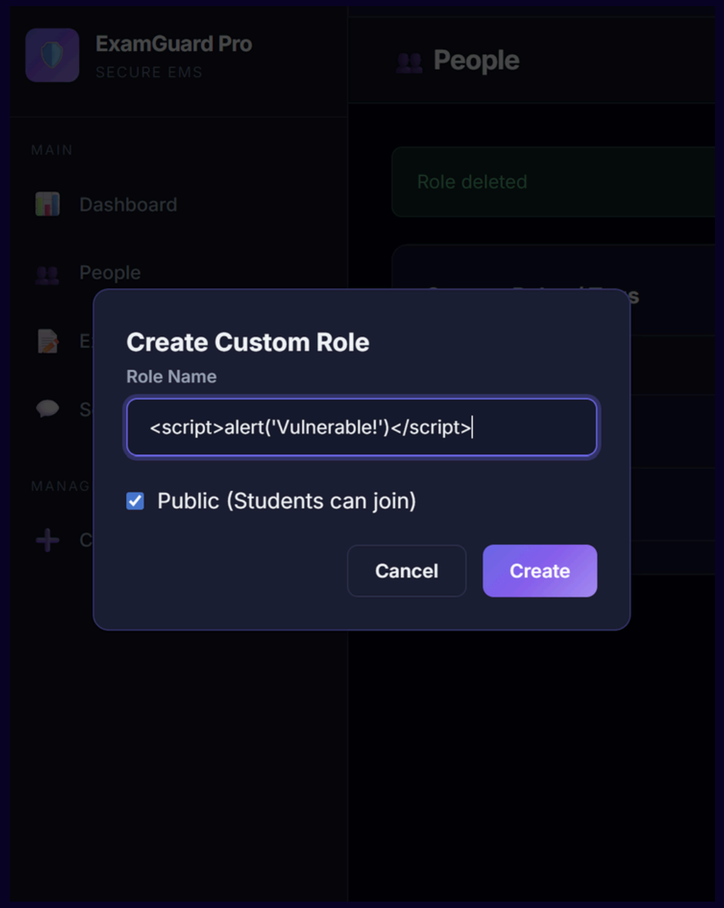
The application uses Prepared Statements with better-sqlite3. The payload is treated as a literal string searching for a user named `' OR '1'='1`, rather than executing the SQL logic.

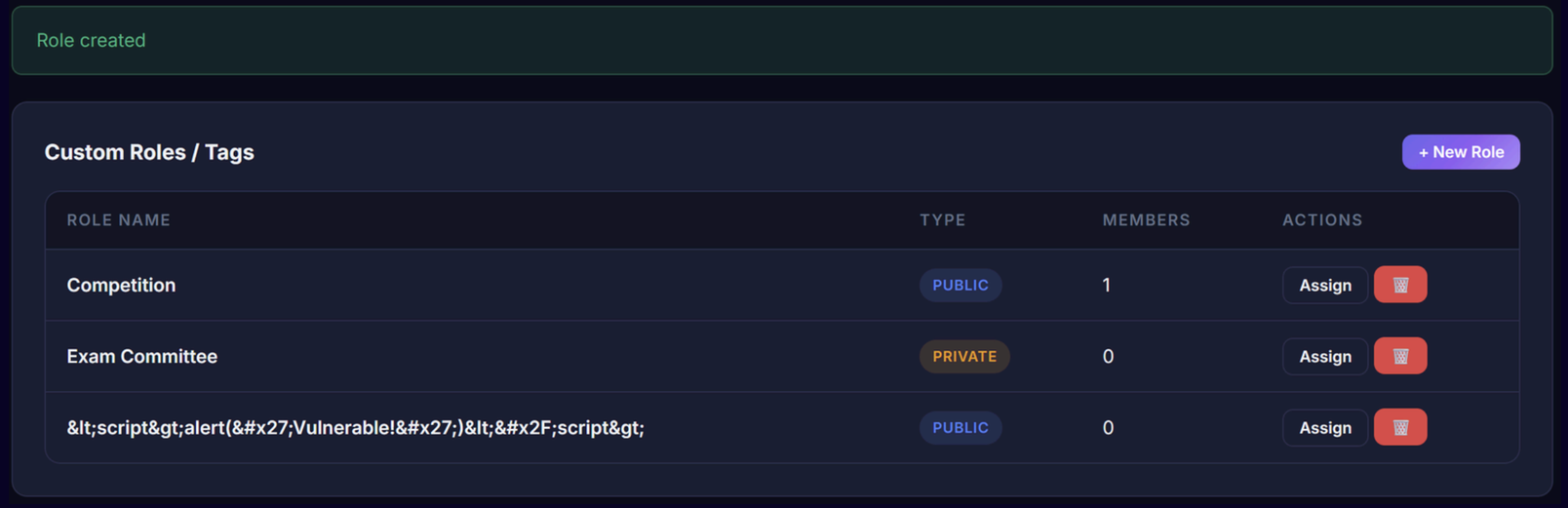
CROSS-SITE SCRIPTING (XSS) & COOKIE SECURITY
COOKIE ACCESSIBILITY (CONSOLE TEST)



The session cookie is marked as HttpOnly, which prevents JavaScript from accessing it, neutralizing most Session Hijacking/Cookie Stealing attacks.

CROSS-SITE SCRIPTING (XSS) & COOKIE SECURITY
UI SCRIPT INJECTION





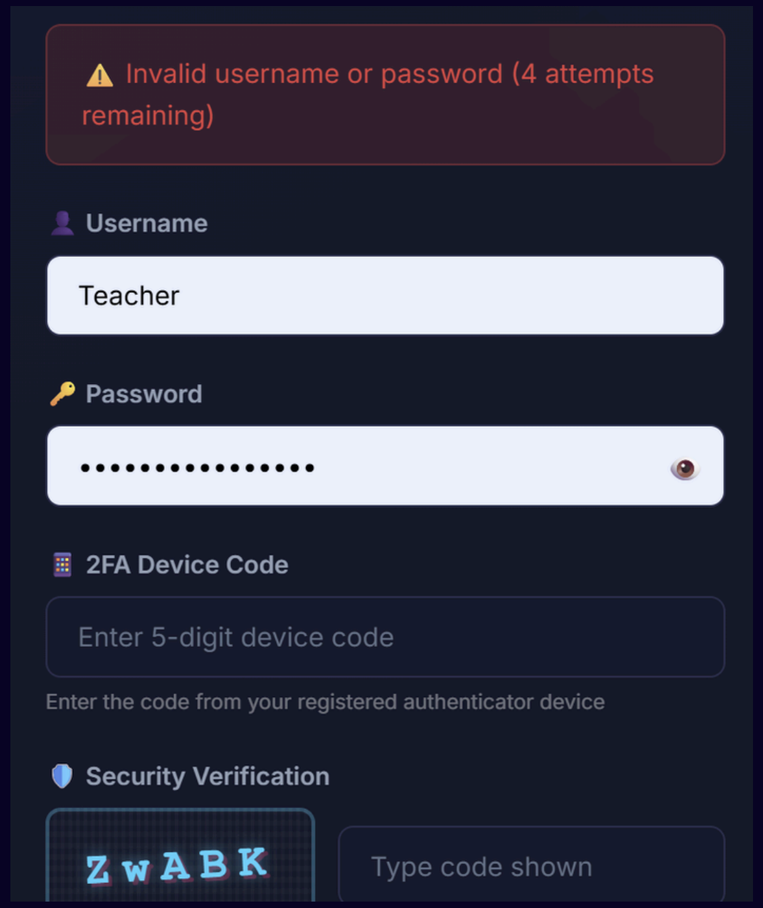
The EJS Templating Engine automatically escapes all output using `<%= %>` tags, converting `<` and `>` into safe HTML entities.

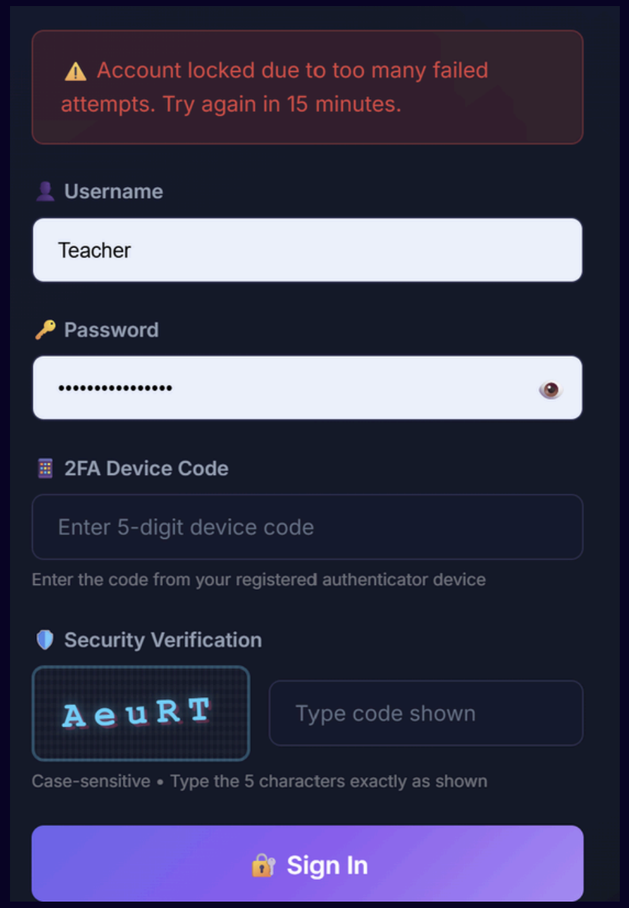
CSRF (CROSS-SITE REQUEST FORGERY) PROTECTION



The `validateCSRFToken` middleware enforces that every `POST` request contains a valid token generated by the server and stored in the user's session.

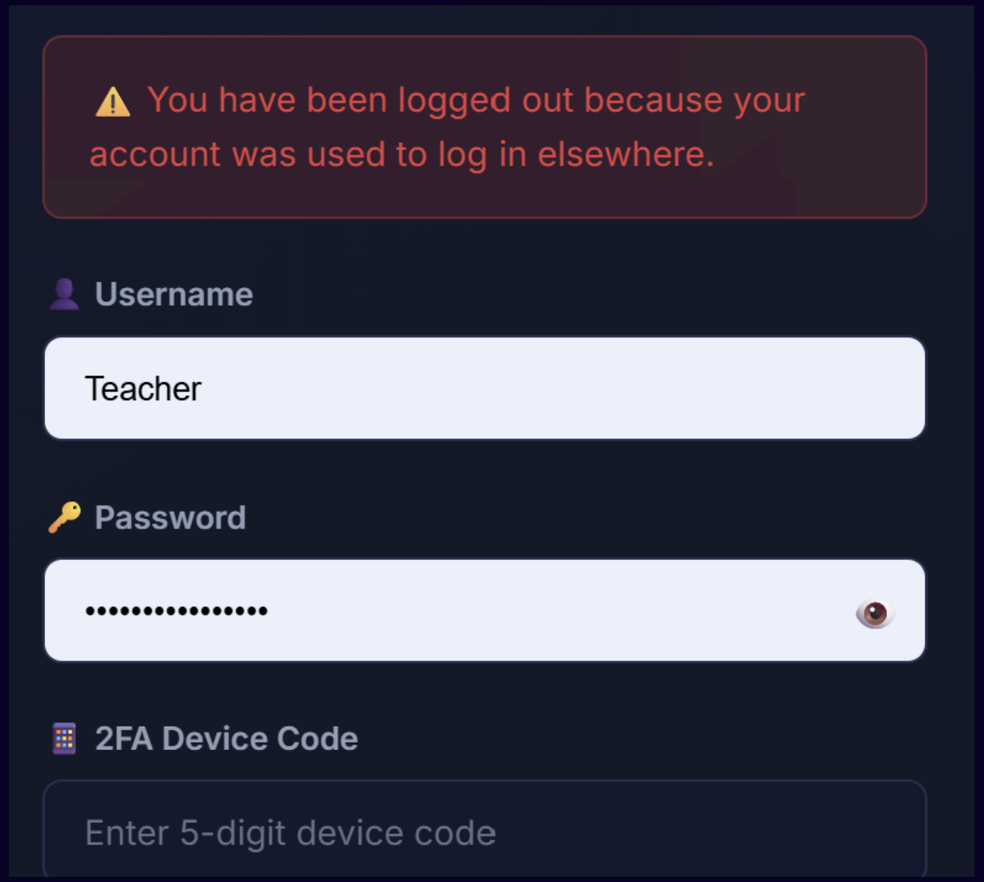
BRUTE FORCE & RATE LIMITING





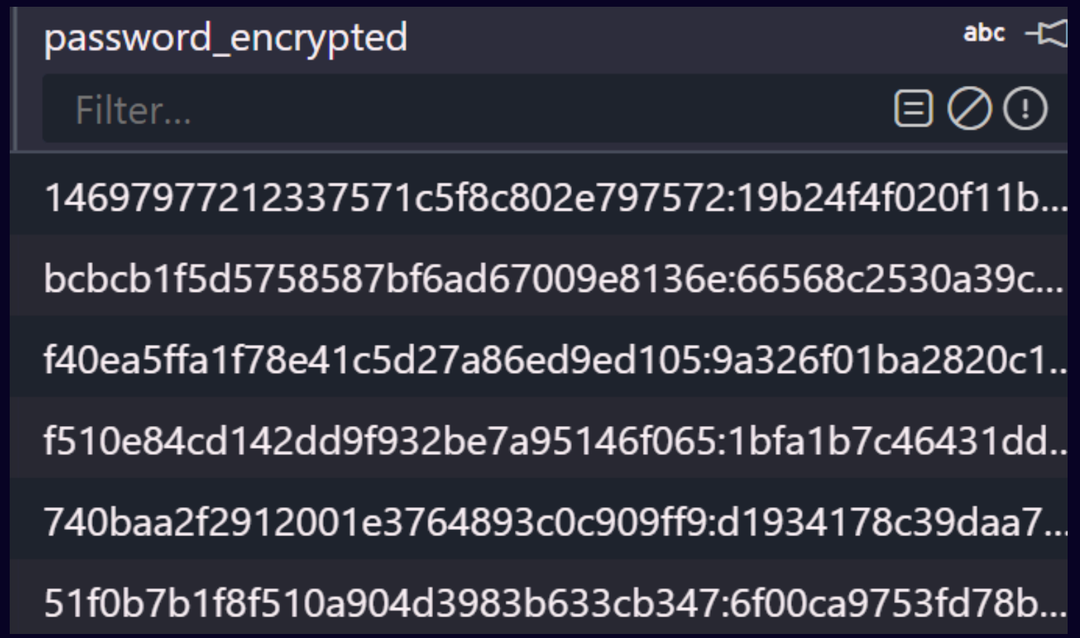
The system tracks `failed_login_attempts` in the `users` table and implements a 15-minute lockout timer once the threshold is reached.

SESSION HIJACKING (SINGLE SESSION ENFORCEMENT)



The server tracks a unique `current_session_id` for every user. When a new login occurs, the old ID is invalidated, and only the most recent login is authorized.

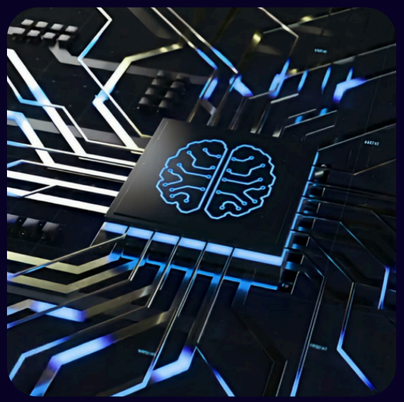
DATA ENCRYPTION (AT REST)



Passwords are never stored. We store a cryptographic hash using PBKDF2 with 100,000 iterations, making it extremely resistant to rainbow table and brute-force attacks even if the database is leaked.
a cryptographic algorithm used to securely hash passwords. It applies a pseudorandom function (like HMAC) repeatedly to the input password along with a salt, making it computationally expensive for attackers to brute-force.

GALALA UNIVERSITY
Powered by
Arizona State University®





THANK YOU